HAFTA 4: Hedefi Tanıma ve Mantık Hataları (Web Recon & IDOR)

Mert ACAR

27.02.2026

Bölüm A: Teori ve Mimari (Research & Logic)

1.Web Anatomisi: HTTP Protokolü:

•http durum 200 kodu sayfanın sorunsuz olarak yüklendiğini söyler. Eğer bu kod karşımıza çıktıysa bulunduğumuz sayfa /.git gibi gizli olması gereken bir dizinse hassas veri sızıntısı yakalamış oluruz.

•http durum 302 kodu sayfanın başka bir adrese taşındığını ve oraya yönlendirdiğini söyler bu bizim için bir şüphe uyandırır. Kullanıcı sayfaya yetkisi olmadığı için mi /login sayfasına yönlendirdi? Yoksa sistem dışarıdan verilen bir URL parametresine güvenerek mi yönlendirme yapıyor? Soruları akıllara gelir.

•http durum 401 kodu sayfanın korunmaya değer, erişime kapalı bir alan var anlamına gelir. Bu genellikle bir giriş paneline, bir API uç noktasına (endpoint) veya HTTP Basic Authentication isteyen bir dizine denk geldiğimizi gösterir.

•http durum 403 kodu sayfanın erişime izinimizin olmadığını gösterir. Bazen de bir WAF (Web Application Firewall) zararlı bir istek yaptığınızı anlayıp bizi engellendiğinde döner.

•http durum 500 kodu sunucuda beklenmedik bir hata oluştuğunu söyler. Bu, gönderdiğimiz özel karakterlerin, payload'ların veya beklenmeyen girdilerin sunucu tarafından düzgün bir şekilde filtrelenmediğini (Exception Handling yapılmadığını) gösterir. Veritabanı veya uygulama mantığı kafası karışıp hata vermiştir.

2.Kimlik ve Yetki: "Sen Kimsin?"

Cookie, Session ve Token:

• Cookie , tarayıcıda verileri saklamayan yaran bir depolama alanıdır. Sunucu tarayıcıya al bu verileri bir sonraki gelişinde getir diyerek verileri verir. O sayfaya yapılan her istekte bu Cookie'yi otomatik olarak sunucuya getirir.

• Session , **sunucu tabanlı (stateful)** bir hatırlama yöntemidir. Giriş yaptığımızda sunucu kendi veya veritabanında bize özel bir alan açar ve bize kod (Session ID: a8f9c2x...) gönderir. Tarayıcı bunu Cookie içine kaydeder , sayfa yenilendiğinde tarayıcı

bu Cookie2yi sunucuya gönderir. Sunucu belleğindeki ve cookie ‘ ye bakar eşleşiyorsa girişe izin verir.

• Token **istemci tabanlı (stateless)** bir hatırlama yöntemidir. Sunucu giriş yaptığımızda kimliğimizi doğrular ve size şifrelenmiş Token verir. Tarayıcı bu Token’ı kaydeder ve istekte bulunduğumuzda sunucuya gönderir. Sunucu Token’ın altındaki **kendi imzasının sahte olup olmadığını** matematiksel olarak kontrol eder. Eşleşiyorsa girişe izin verir.

Authentication vs Authorization:

. Authentication (Kimlik Doğrulama): Sisteme başarıyla girdiğimizi (Login) . Yöntemleri parolalar, parmak izi okuyucular (biyometrik) telefonumuza gelen SMS doğrulama kodları bu katmanın araçlarıdır.

. Authorization (Yetkilendirme): Kimliğinizi doğrulayıp içeri girdikten sonra sistemin bize koyduğu **sınırlar ve izinlerdir.**

Girdiğimiz sistemde başkasının mesajlarını okuyabilmek (IDOR - Insecure Direct Object Reference), kesinlikle bir **Yetkilendirme (Authorization)** zafiyetidir. Modern adıyla BOLA (Broken Object Level Authorization) olarak da bilinir ve API'lerdeki en tehlikeli açıklardan biridir. Çünkü IDOR yapabilmemiz için sadece sisteme giriş yapmak yetmez . Geçerli bir Session veya Token’a sahip olmamız gerekir.

3.Zafiyet Mimarisi: IDOR

IDOR (Insecure Direct Object Reference):

Web uygulamalarındaki en yaygın, sömürülmesi en kolay ama aynı zamanda en tehlikeli mantık hatalarından biridir.

Giriş yapmış (Authenticated) her kullanıcının, talep ettiği veriye erişmeye yetkisi (Authorized) olduğunu varsaymasıdır.

Yazılımcı, kullanıcının sisteme giriş yapıp yapmadığını kontrol eder, ancak **"İstenen bu veri (nesne) gerçekten bu kullanıcıya mı ait?"** sorusunu (Sahiplik Kontrolü) sormayı unutur.

Bölüm B: Saha Eğitimi (TryHackMe & Dorking)

Görev 1: İnternetin Röntgeni (TryHackMe):

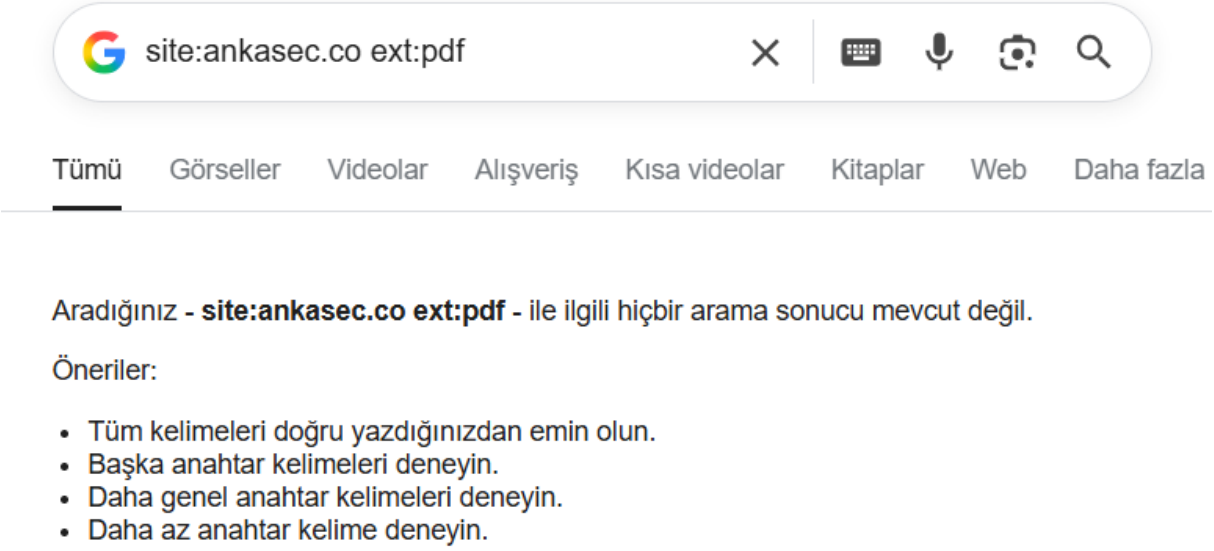
Oda:

İstenen:

•Host (Sunucu Adı) Parametresi , tarayıcı bir IP adresine bağlandığında, sunucuya hangi web sitesi görmek istediğinin cevabı Host başlığı ile verilir.

•User-Agent (Kullanıcı Temsilcisi) Parametresi , isteği yapan tarayıcının adını (Chrome,Firefox), sürümünü , kullanılan işletim sistemini ve cihaz tipini barındırır.

Görev 2: Google Dorking (Açık Kaynak İstihbaratı) :



site:tesla.com ext:pdf

Tümü | Görseller | Videolar | Alışveriş | Kısa videolar | Haberler | Kitaplar

Tesla
https://www.tesla.com › en_eu › Owners_Manual PDF

MODEL Y

16 Ara 2025 — For the latest and greatest information that is customized to your vehicle, vie
Owner's Manual on your vehicle's touchscreen.
304 sayfa

Tesla
https://www.tesla.com › default › files › pdfs › P... PDF

Powerwall 2 AC Installation Manual

PRODUCT SPECIFICATIONS. All specifications and descriptions contained in this documer
to be accurate at the time of printing.
71 sayfa

Tesla Service
https://service.tesla.com › docs · Bu sayfanın çevirisini yap

Model 3 Service Manual

Model 3 Service Manual · Introduction · How to Use this Manual · Repairs and Replacemei
Practices · Airbag and Supplementary Restraint System (SRS) ...

Tesla
https://www.tesla.com › ns_videos › 2024-tesla-i... PDF

Impact Report '24

BÖLÜM C: Operasyonel Görev (Boss Fight)

Cephe 1: Hayalet Avı (Recon Haritası):

```
C:\Windows\System32\cmd.e

C:\Users\LENOVO\Documents\OneDrive\Desktop\Pentest>.\subfinder.exe -d tesla.com -o tesla_sub.txt

                __     _____            __
   _______  __/ /_   / __(_)___  ____/ /__  _____
  / ___/ / / / __ \/ /_/ / __ \/ __  / _ \/ ___/
 (__  ) /_/ / /_/ / __/ / / / / /_/ /  __/ /
/____/\__,_/_.___/_/ /_/_/ /_/\__,_/\___/_/

                projectdiscovery.io

[INF] Current subfinder version v2.12.0 (latest)
[INF] Loading provider config from C:\Users\LENOVO\AppData\Roaming\subfinder\provider-config.yaml
[INF] Enumerating subdomains for tesla.com
url1894.tesla.com
url4211.tesla.com
akamai-apigateway-vfx.tesla.com
autodiscover.tesla.com
origin-wwwcdn.tesla.com
sjc36-gpgw1.tesla.com
doraemon-svc-apac-stg.tesla.com
mobile-ops-links.prd.vn.cloud.tesla.com
powerhub.energy.tesla.com
my.tesla.com
akamai-apigateway-stg-inventorytxnextapi.tesla.com
bi.tesla.com
mfa-stage.tesla.com
openadrclient.tesla.com
x3-eng.obs.tesla.com
fsx.tesla.com
inference.bottlerocket.tesla.com
```

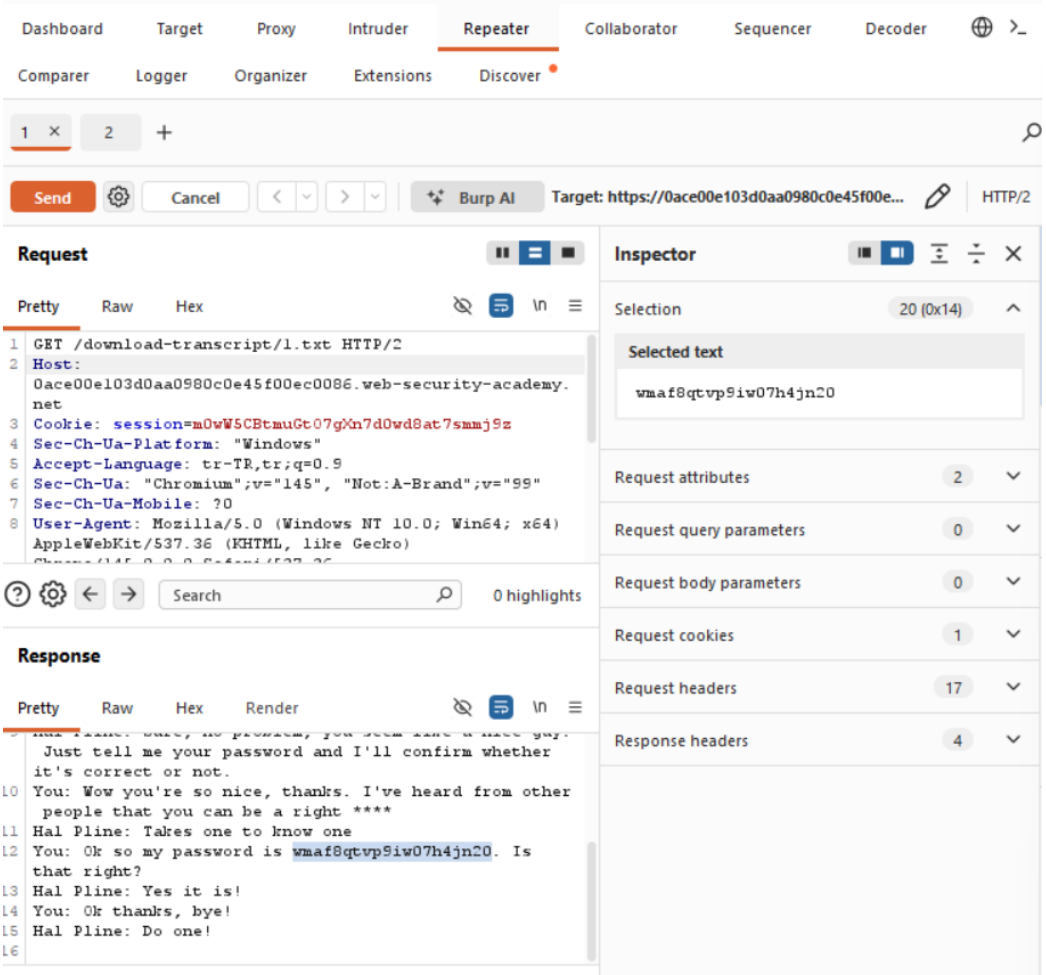
```
C:\Users\LENOVO\Documents\OneDrive\Desktop\Pentest>.\httpx.exe -l tesla_sub.txt -sc -title

    __    __  __       _  __
   / /_  / /_/ /_____ | |/ /
  / __ \/ __/ __/ __ \|   /
 / / / / /_/ /_/ /_/ /   |
/_/ /_/\__/\__/ .___/_/|_|
             /_/

                projectdiscovery.io

[INF] Current httpx version v1.8.1 (latest)
[WRN] UI Dashboard is disabled, Use -dashboard option to enable
https://akamai-apigateway-finplateng-routeone.tesla.com [403] [Access Denied]
https://akamai-apigateway-ehs-stg.tesla.com [403] [Access Denied]
https://akamai-apigateway-bender.tesla.com [301]
https://akamai-apigateway-dev-warptmsapiserver-upgrade.tesla.com [503] [Error]
https://akamai-apigateway-einvoicing.tesla.com [301]
https://akamai-apigateway-dev-captiveunderwriting.tesla.com [503] [Error]
https://akamai-apigateway-mfs-supplier-uat.tesla.com [503] [Error]
https://akamai-apigateway-dev-warptmsapiserver.tesla.com [503] [Error]
https://akamai-apigateway-qa-captiveunderwriting.tesla.com [503] [Error]
https://akamai-apigateway-finplateng-defi.tesla.com [403] [Access Denied]
https://akamai-apigateway-payment.tesla.com [503] [Service Unavailable]
https://akamai-apigateway-mfs-supplier.tesla.com [503] [Service Unavailable]
https://akamai-apigateway-ops-warp3pl.tesla.com [503] [Service Unavailable]
https://akamai-apigateway-captiveunderwriting.tesla.com [503] [Service Unavailable]
https://akamai-apigateway-deliveryopsvitu.tesla.com [503] [Service Unavailable]
https://akamai-apigateway-packaging2.tesla.com [503] [Service Unavailable]
```

Cephe 2: Yetkiyi Delmek (PortSwigger Labs):



Web Security Academy

Insecure direct object references

Back to lab description

LAB Solved

Congratulations, you solved the lab!

Share your skills! Continue learning

Home | My account | Live chat | Log out

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder

Comparer Logger Organizer Extensions Discover

1 2 3

Send Cancel Burp AI Target: https://0a230057041defce80ce8084002... HTTP/2

Request

Pretty Raw Hex

```
1 GET /my-account?id=carlos HTTP/2
2 Host:
  0a230057041defce80ce808400280010.web-security-academy.
  net
3 Cookie: session=z4RHy3BDkVShGx9qJYAA64CjlqfglPk4
4 Cache-Control: max-age=0
5 Accept-Language: tr-TR,tr;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/145.0.0.0 Safari/537.36
```

Search 0 highlights

Response

Pretty Raw Hex Render

```
60                  <div id=account-content>
61                      <p>
                            Your username is: carlos
                        </p>
62                      <div>
                            Your API Key is:
                            iK4ccZUceAxxBEW48Exd581MVmrjQ
                            bSo
                        </div>
                        <br/>
63                      <form class="login-form" name="
```

Search 0 highlights Selection: 32 (0x20)

Inspector

Selection 32 (0x20)

Selected text

iK4ccZUceAxxBEW48Exd581MVmrjQbSo

Request attributes 2

Request query parameters 1

Request body parameters 0

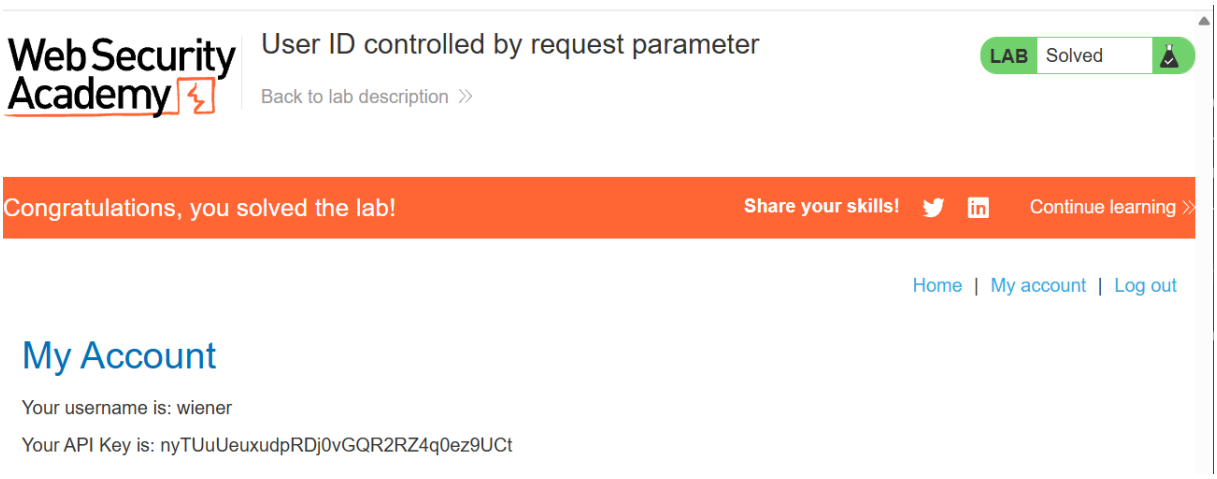
Request cookies 1

Request headers 20

Response headers 4

Inspector Notes Custom actions

Done 3,802 bytes | 155 millis



Zafiyet Sömürü Raporu: Burp Suite ile IDOR (Insecure Direct Object Reference) Analizi

1. Keşif ve Trafiği Yakalama (Proxy İşlemleri) "Test sürecime, hedef uygulamaya giden tüm HTTP/HTTPS trafiğini analiz edebilmek için Burp Suite'in dahili tarayıcısını (Chromium) açarak başladım. Sistemi normal bir kullanıcı gibi deneyimlemek ve akışı bozmamak adına Proxy > Intercept sekmesindeki araya girme özelliğini kapalı ('Intercept is off') konuma getirdim.

Sistemde bana verilen düşük yetkili test kullanıcısı (örneğin wiener) ile oturum açtım. Kendi profil sayfama ve sohbet geçmişi gibi kişisel verilerime erişim sağladım. Bu esnada tarayıcım ile sunucu arasındaki tüm veri alışverişi Burp Suite tarafından arka planda sessizce kaydedildi."

2. Zafiyetli Uç Noktanın Tespiti (HTTP History) "Hedef işlemi gerçekleştirdikten sonra Burp Suite arayüzünde Proxy > HTTP history sekmesine geçiş yaptım. Tarayıcıda oluşan trafik loglarını inceleyerek, kişisel verilerimi sunucudan çeken o spesifik GET isteğini tespit ettim.

İsteğin URL yapısını detaylıca incelediğimde, sunucunun hangi veriyi getireceğine doğrudan URL içindeki bir parametreye bakarak karar verdiğini fark ettim (Örneğin: GET /my-account?id=wiener veya GET /download-transcript/2.txt). Geliştiricinin arka planda kullanıcının yetkisini doğrulamak yerine, sadece bu parametreye güvendiğinden (Sıfır Güven ihlali) şüphelendim."

3. Analiz Ortamına Aktarım (Repeater) "Şüphelendiğim bu zafiyeti kanıtlamak için, ilgili isteğin üzerine sağ tıklayıp 'Send to Repeater' seçeneğini kullanarak paketi çalışma alanıma aktardım. Repeater modülü, yakaladığım tekil bir HTTP paketini dilediğim gibi modifiye edip sunucuya tekrar tekrar göndermeme olanak tanıdığı için manuel testlerin en kritik aşamasıdır."

4. Parametre Manipülasyonu ve Veri İhlali (Exploitation) "Repeater sekmesine geçerek sol taraftaki Request (İstek) penceresinde yetki yükseltme denememi gerçekleştirdim. URL içerisinde bana ait olan yetkili girdi değerini (örn: id=wiener) silerek, sistemdeki başka bir kullanıcının veya yöneticinin hedef değeriyle (örn: id=carlos) değiştirdim.

Manipüle edilmiş yeni isteği sunucuya iletmek için 'Send' butonuna bastım. Sağ taraftaki Response (Yanıt) penceresini incelediğimde uygulamanın isteğimi reddetmediğini ve HTTP/1.1 200 OK başarılı durum kodunu döndürdüğünü tespit ettim.

Yanıtın gövde (Body) kısmını incelediğimde; hiçbir erişim yetkim olmamasına rağmen, hedef kullanıcının profiline ait çok gizli API Key değerini (veya sohbet dökümündeki şifreyi) açık metin olarak başarılı bir şekilde ele geçirdim. Bu durum, sistemdeki Broken Access Control / IDOR zafiyetinin varlığını ve kritik risk seviyesini kesin olarak kanıtlamaktadır."

BÖLÜM D: Mühendislik Vizyonu (Reflection)

1. **IDOR'un Gerçek Hayat Etkisi (Impact):**

KVKK (Türkiye) Kapsamında Maliyet: KVKK Madde 12, veri sorumlusuna veri güvenliğini sağlama yükümlülüğü getirir. Sağlık verilerinin (HIV, Kanser vb.) herkes tarafından id değiştirilerek görülebilmesi, teknik tedbirlerin (yetki kontrolü) alınmadığının kesin kanıtıdır.

GDPR Kapsamında Maliyet: Eğer hastalar arasında Avrupa Birliği vatandaşları varsa veya sistem GDPR'a tabi ise, verilecek ceza şirketin **küresel yıllık cirosunun %4'üne veya 20 Milyon Euro'ya** (hangisi daha yüksekse) kadar çıkabilir.

Marka itibarı aşağıdaki sorunları oluşturur:

- Güven Çöküşü: Müşteriler, "Benim tahlilimi de başkaları gördü mü?" paniğiyle hastaneden hizmet almayı anında keser.
- Kurumsal İptaller: Hastane ile anlaşmalı olan özel sağlık sigortaları ve kurumsal şirketler, müşterilerini riske atmamak için anlaşmalarını hızla fesheder.
- Medya Krizi: "X Hastanesinde Büyük Skandal: Hastaların HIV ve Kanser Sonuçları İnternete Düştü" gibi haber başlıkları, o hastanenin marka değerini geri döndürülemez şekilde sıfırlar. PR kampanyaları bu hasarı onarmaya yetmez.

- **İş Etkisi (Business Impact):** Bu zafiyet, saldırganların hiçbir özel yeteneğe veya ek araca ihtiyaç duymadan, yalnızca tarayıcı üzerindeki URL parametresini ardışık olarak değiştirerek sistemdeki **tüm hastaların en hassas sağlık verilerine (HIV, Kanser, genetik sonuçlar) erişmesine** olanak tanımaktadır.

- Verilerin izinsiz okunabilir olması (Confidentiality ihlali), KVKK'nın "Özel Nitelikli Kişisel Verilerin Korunması" (Madde 6) şartlarının doğrudan ihlalidir. Bu zafiyetin kötü niyetli kişilerce sömürülüp verilerin sızdırılması halinde; kurumumuz doğrudan milyonlarca liralık cezai yaptırımlar, kitlesel tazminat davaları ve geri döndürülemez bir hasta güveni kaybı ile karşı karşıya kalacaktır.

2. Güvenin Bedeli (Zero Trust):

•**Sahiplik Doğrulaması (Ownership Verification):** Çekilen kaydın bir ownerId veya userId alanı olmalı ve bu alan, isteği yapan kullanıcının ID'si ile her endpoint'te karşılaştırılmalıdır.

• **Doğrudan Veritabanı Sorgusunda Kısıtlama (Daha İyi Performans):** Veriyi önce çekip sonra if/else ile kontrol etmek yerine, sorguyu atarken kullanıcıyı da şarta ekleyebilirsin: const order = await Order.findOne({ _id: orderId, userId: loggedInUserId }); Eğer kayıt dönmezse, ya öyle bir sipariş yoktur ya da başkasına aittir. Her iki durumda da güvenli kalırsın.

• **Tahmin Edilemez ID'ler (UUID/GUID):** Veritabanı şemalarını tasarlarken otomatik artan 1, 2, 3 gibi ID'ler yerine, f47ac10b-58cc-4372-a567-0e02b2c3d479 gibi UUID'ler (Mongoose'da genellikle varsayılan _id olan ObjectId'ler de tahmin edilmesi zor bir yapıdadır) kullanmalısın. Bu, IDOR'u tamamen çözmez ama sömürülmesini (mass-exploitation) çok zorlaştırır.